

TAREA NDC01

Introducción al cumplimiento normativo.

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Cumplimiento y Normativa	3
Respuestas 1	3
Respuestas 2	4
Apartado 2: Buen Gobierno y Ética Empresarial.....	5
Respuestas 3	5
Respuestas 4	6
Apartado 3: Relaciones con Terceras Partes	6
Respuestas 5	6

Detalles de la tarea de esta unidad

Caso práctico

- *Innovatech Solutions es una empresa tecnológica española en plena expansión, con una plantilla de 150 empleados. Se especializa en el desarrollo de software a medida que utiliza inteligencia artificial (IA) para optimizar la cadena de suministro de empresas de logística. Su software gestiona datos críticos de sus clientes, como rutas de transporte, inventarios y datos de destinatarios finales.*
- *La empresa tiene una cartera de clientes nacionales e internacionales, incluyendo una importante compañía farmacéutica de Estados Unidos, lo que les obliga a ser extremadamente cuidadosos con la privacidad y la seguridad de los datos que manejan.*
- *Recientemente, Innovatech ha sufrido una fuga de datos menor que fue contenida a tiempo, pero que ha encendido las alarmas en la dirección. Como resultado, la empresa se ha puesto como objetivo prioritario obtener la certificación ISO 27001 en su nueva versión de 2022 para reforzar la confianza de sus clientes. Además, para financiar su expansión, la dirección está preparando a la empresa para una futura salida a bolsa.*
- *Todo el desarrollo y la infraestructura de Innovatech opera sobre servicios de un conocido proveedor de computación en la nube (Cloud). La dirección, consciente de los nuevos retos legales y éticos, quiere asegurarse de que la empresa no solo cumple con la normativa, sino que también opera bajo los más altos estándares de buen gobierno y ética empresarial.*

Apartado 1: Cumplimiento y Normativa

1.- La nueva Ley 2/2023 obliga a las empresas a implementar un canal de denuncias. Considerando que Innovatech tiene 150 empleados, ¿qué obligaciones específicas tiene al respecto? ¿Podría compartir recursos con otras empresas para gestionar este canal?

Respuestas 1

Una vez revisada la información al respecto:

<https://www.boe.es/boe/dias/2023/02/21/pdfs/BOE-A-2023-4513.pdf>

Artículo 10. Entidades obligadas del sector privado. 1. Estarán obligadas a disponer un Sistema interno de información en los términos previstos en esta ley: a) Las personas físicas o jurídicas del sector privado que tengan contratados cincuenta o más trabajadores.

- Como Innovatech tiene 150 empleados, está obligada a disponer de un canal interno de denuncias según dicha ley.

Artículo 5. Sistema interno de información.

- b) Estar diseñado, establecido y gestionado de una forma segura, de modo que se garantice la confidencialidad*
- c) Permitir la presentación de comunicaciones por escrito o verbalmente.*
- d) Integrar los distintos canales internos de información que pudieran establecerse dentro de la entidad.*
- e) Garantizar que las comunicaciones presentadas puedan tratarse de manera efectiva.*
- f) Ser independientes y aparecer diferenciados respecto de los sistemas internos de información.*
- g) Contar con un responsable del sistema en los términos previstos en el artículo 8.*
- j) Establecer las garantías para la protección de los informantes.*

- En resumen, deberá asegurar confidencialidad, permitir varios canales de denuncia, garantizar el tratamiento, designar un responsable del canal, además de garantizar la protección contra represalias.

Artículo 12. Medios compartidos en el sector privado. Las personas jurídicas en el sector privado que tengan entre cincuenta y doscientos cuarenta y nueve trabajadores y que así lo decidan, podrán compartir entre sí el Sistema interno de información y los recursos destinados a la gestión y tramitación de las comunicaciones, tanto si la gestión se lleva a cabo por cualquiera de ellas como si se ha externalizado, respetándose en todo caso las garantías previstas en esta ley.

- Como indica la ley, también puede compartir recursos para gestionarlo con otras empresas de entre 50 y 249 empleados.

2.- Innovatech busca la certificación ISO 27001:2022. Menciona y describe brevemente dos de los nuevos controles introducidos en esta versión que serían especialmente importantes para una empresa como Innovatech y su modelo de negocio (p. ej., seguridad en la nube, inteligencia de amenazas).

Respuestas 2

Una vez revisada la información de las fuentes:

<https://www.ccn-cert.cni.es/es/800-guia-esquema-nacional-de-seguridad/543-ccn-stic-825-ens-iso27001/file.html>

- Seguridad en la nube: La seguridad de los servicios cloud debe definirse mediante procesos y procedimientos e implementarse para abordar los riesgos de seguridad de la información asociados con los servicios de TIC y la cadena de suministro de productos.

- Inteligencia de amenazas: Se recopilará información relacionada con las amenazas a la seguridad y se analizarán para generar información sobre amenazas para anticipar incidentes.

Apartado 2: Buen Gobierno y Ética Empresarial

3.- La dirección de Innovatech se prepara para una futura salida a bolsa, lo que implica un mayor escrutinio por parte de inversores y reguladores. Desde la perspectiva del buen gobierno corporativo, ¿qué responsabilidades específicas debería asumir el Consejo de Administración en materia de ciberseguridad y supervisión del uso ético de la IA? Describe al menos dos responsabilidades para cada área (ciberseguridad y ética en IA).

Respuestas 3

Ciberseguridad:

https://cnmv.es/DocPortal/Ciberseguridad/CBG_Ciberseguridad.pdf

- Las organizaciones, en función de su complejidad y exposición al riesgo cibernético, deberán tener en cuenta la ciberseguridad al menos en uno de sus comités de crisis.
- Existirá un comité de ciberseguridad, constituido formalmente, en el que estarán representado, además del CISO, un número adecuado de áreas de la organización para adoptar cualquier resolución, con relevancia en materia de seguridad de la información, que pueda afectar sustancialmente a la actividad de la organización.

Ética en IA:

https://www.cnmv.es/DocPortal/Publicaciones/CodigoGov/CBG_2020.pdf

- Establecer políticas para el uso responsable y transparente de la IA,
- Revisar riesgos éticos como sesgos y privacidad, Recomendación 45: La política de control y gestión de riesgos debe identificar riesgos tecnológicos, legales, sociales, medioambientales, políticos y reputacionales.

4.- El uso de Inteligencia Artificial conlleva nuevos dilemas éticos. Propón cinco principios o normas que incluirías en el código ético de Innovatech, centrados específicamente en el desarrollo ético de la IA y la protección de la privacidad de los datos que sus sistemas procesan.

Respuestas 4

En mi opinión y basado en el estudio y la experiencia me basaría en los siguientes principios:

- Uso de la IA de forma transparente.
- Control del uso de IA evitando exposición de datos de la compañía de carácter privado en una exposición fuera del alcance permitido.
- Control de sesgos para evitar las llamadas alucinaciones.
- Establecer los mecanismos de seguridad necesarios para evitar fugas de información.
- Cumplimiento de las normativas de protección de datos (tanto RGPD, como LOPD)

Apartado 3: Relaciones con Terceras Partes

5.- Toda la operación de Innovatech depende de su proveedor de servicios en la nube. Describe qué elementos clave analizarías en un proceso de diligencia debida para asegurar que este proveedor externo cumple con los requisitos de seguridad y normativos que Innovatech necesita para protegerse a sí misma y a sus clientes.

Respuestas 5

En base a lo aprendido en el apartado del tema de Relaciones con terceras partes en compliance.

Dividiremos el análisis en las siguientes fases:

- Evaluación:

Se deben analizar las diferentes certificaciones (ISO 27001, ENS, etc.), ubicación de los datos, cumplimiento RGPD, cifrado, tanto de los datos como del tránsito de los mismos, histórico de incidentes o sanciones.

- Formalización:

Niveles de servicios (SLA) definidos y como se miden, procedimientos ante incidentes y planes de continuidad ante desastres.

- Monitorización

Revisión periódica de certificaciones, auditorías y controles, comprobación sistemática del cumplimiento de SLA y métricas de seguridad además de canales de comunicación y respuesta ante incidentes.